
SOC 2 Readiness Documentation

Controls mapped to the AICPA Trust Services
Criteria

Voight

June 2026

Contents

Document Control	2
1. What This Document Is — and Is Not	3
1.1 The Honest Statement	3
1.2 Readiness vs. Type I vs. Type II	3
1.3 Why Publish a Readiness Document at All	3
2. System Description	4
3. Security — Common Criteria	5
3.1 CC1 — Control Environment	5
3.2 CC2 — Communication and Information	5
3.3 CC3 / CC4 — Risk Assessment and Monitoring	5
3.4 CC5 — Control Activities	6
3.5 CC6 — Logical and Physical Access	6
3.6 CC7 — System Operations	7
3.7 CC8 — Change Management	7
3.8 CC9 — Risk Mitigation (Vendors)	8
4. Availability	9
5. Confidentiality	10
6. Known Gaps	11
7. Inherited Controls	12
8. Roadmap to a Type II Report	13
9. Governance and References	14
Annex A — Document Version History	15
Contact	16

Document Control

Field	Value
Document Title	SOC 2 Readiness Documentation
Document Version	1.0
Framework Tracked	AICPA Trust Services Criteria (2017, with 2022 revised points of focus)
Criteria In Scope	Security (Common Criteria), Availability, Confidentiality
Status	Published — Readiness (not an audit report)
Issue Date	June 10, 2026
Owner	Voight — Security Office
Approver	Founding Team
Classification	Public
Next Review	December 10, 2026

This document describes the state of Voight’s internal controls, mapped to the AICPA Trust Services Criteria that govern SOC 2 examinations. It is written for procurement teams, security reviewers, and customers who ask the question “do you have SOC 2?” — and it answers that question honestly.

1. What This Document Is — and Is Not

1.1 The Honest Statement

Voight is not SOC 2 certified. No SOC 2 Type I or Type II examination of Voight has been performed by a licensed CPA firm, and no SOC 2 report exists.

What this document *is*: a public, versioned **readiness assessment** — a self-prepared mapping of Voight’s implemented controls against the Trust Services Criteria a SOC 2 auditor would evaluate. It records what is in place, what is partially in place, and what is missing, so that a reader can judge Voight’s security posture on evidence rather than on a marketing claim.

1.2 Readiness vs. Type I vs. Type II

	Readiness (this document)	SOC 2 Type I	SOC 2 Type II
Produced by	Voight (self-assessment)	Licensed CPA firm	Licensed CPA firm
What it attests	Controls are designed and documented	Controls are suitably designed at a point in time	Controls operated effectively over a 3–12 month period
Independent verification	None	Yes	Yes
Output	This public document	Auditor’s report (under NDA)	Auditor’s report (under NDA)

A SOC 2 Type II examination is on Voight’s roadmap; its timing will be driven by enterprise customer demand. When an examination is engaged, this document will be updated to say so, and when a report is issued, this document will be replaced by an attestation summary with the report available under NDA.

1.3 Why Publish a Readiness Document at All

Three reasons:

1. **It answers the procurement question truthfully.** “We have a public readiness assessment and a Type II on the roadmap” is a verifiable answer; silence or a vague “we’re working on it” is not.
2. **It is the working paper for the future audit.** The control mapping below is the same mapping an auditor will start from.
3. **It keeps us honest.** Publishing the gaps (§6) creates pressure to close them.

2. System Description

A SOC 2 report begins with a description of the system under examination. The equivalent for Voight:

Service. Voight is an observability platform for AI applications. Customers install an SDK ([@voightxyz/sdk](#) on npm, [bitfrost](#) on PyPI) in their own applications; the SDK captures telemetry about LLM calls — model, tokens, latency, tool calls, cost, outcomes, and (subject to the customer’s privacy level) prompt and completion content — and ships it to Voight’s ingest API. Customers view their telemetry in a dashboard at [voight.xyz](#).

Infrastructure.

Component	Provider	Notes
Dashboard and marketing site	Vercel	Global edge, primary region US
Ingest API (api.voight.xyz)	Railway	US-West region
Postgres database + backups	Railway	US-West region, encrypted volumes
Authentication	Privy	DID-based identity; Voight stores no passwords

People. Voight is operated by its founding team. All production access is limited to identified founders under written confidentiality obligations.

Data. The categories of data Voight stores, where they live, and how long they are retained are catalogued in Voight’s GDPR Compliance Documentation (Annex B), which this document incorporates by reference.

3. Security — Common Criteria

The Security criteria (CC-series) are mandatory in every SOC 2 examination. Status legend: **In place** · **Partial** · **Planned**.

3.1 CC1 — Control Environment

Control	Status	Evidence
Confidentiality obligations for all personnel with production access	In place	Written founder obligations
Security responsibility assigned (Security Office, founding team)	In place	This document; GDPR doc §15
Formal organisational chart and HR screening process	Planned	Single founding team today; formalises with first hires

3.2 CC2 — Communication and Information

Control	Status	Evidence
Public security and privacy documentation	In place	docs.voight.xyz/trust (GDPR, OWASP, NIST, this document)
Customer-facing changelog for material changes	In place	docs.voight.xyz/changelog
Security contact published	In place	team@voight.xyz , 48-hour acknowledgement

3.3 CC3 / CC4 — Risk Assessment and Monitoring

Control	Status	Evidence
Documented risk framing for AI-specific risks	In place	OWASP LLM Top 10 and NIST AI RMF alignment documents

Control	Status	Evidence
Dependency vulnerability monitoring	In place	GitHub Dependabot on all repositories
Defined remediation SLAs (critical 7d / high 30d / medium 90d)	In place	GDPR doc §8.6
Periodic formal risk assessment cycle	Partial	Six-monthly document review cycle exists; dedicated risk register matures with the audit

3.4 CC5 — Control Activities

Control	Status	Evidence
Controls embedded in the SDK by design (local PII scrubbing, privacy levels)	In place	voight-sdk/src/privacy.ts , public test suite
Per-event audit stamps (privacyLevel)	In place	Dashboard event chips

3.5 CC6 — Logical and Physical Access

Control	Status	Evidence
TLS 1.3 on all public endpoints	In place	SSL Labs-verifiable
AES-256 encryption at rest (database and backups)	In place	Railway encrypted volumes
API keys (vk_) hashed at rest, 256-bit entropy, revocable	In place	Schema: ApiKey.hash
No password storage (auth delegated to Privy)	In place	Privy-brokered DID
Least-privilege production access, logged	In place	Access restricted to founders

Control	Status	Evidence
Two-factor authentication on infrastructure accounts	In place	Provider SSO + 2FA
Physical security	Inherited	Vercel / Railway data-centre controls (their SOC 2 reports)

3.6 CC7 — System Operations

Control	Status	Evidence
Application and access logging, 90-day retention	In place	GDPR doc §8.5
Anomaly alerting (event surge, error rate, cost spike)	In place	Built-in alert rules
Written incident-response procedure with timeframes	In place	GDPR doc §11 (T+0 to T+7d)
Breach notification procedure (72h regulator, direct to affected users)	In place	GDPR doc §11
24/7 formal on-call rotation	Planned	Founder on-call today; formalises with team growth

3.7 CC8 — Change Management

Control	Status	Evidence
Version control for all code and documentation	In place	GitHub, signed commits (DCO)
CI checks before deploy	In place	GitHub Actions
npm packages published with provenance attestations	In place	npm -- provenance
Formal change-approval workflow with segregation of duties	Partial	Single-team reality today; PR review formalises with first hires

3.8 CC9 — Risk Mitigation (Vendors)

Control	Status	Evidence
Vendor register with compliance posture	In place	GDPR doc Annex A — all three vendors SOC 2 Type II
Vendor DPAs executed/incorporated	In place	Vercel, Railway, Privy published DPAs
30-day advance notice of new vendors	In place	Changelog commitment, GDPR doc §9

4. Availability

Control	Status	Evidence
Hosting on providers with redundant infrastructure	In place	Vercel edge network; Railway managed platform
Database backups, 30-day rolling window, same-region	In place	Railway automated backups
Capacity signals monitored (ingest rate, DB size)	In place	Railway metrics + internal dashboards
Rate limiting to protect ingest availability (per-tier burst)	In place	60/min Free, 600/min Pro
Public status page	Planned	Ships alongside v1.0
Documented recovery procedure with tested RTO/RPO	Partial	Backups restorable via Railway; formal recovery test pending
Contractual SLA	Planned	Enterprise tier; SLA terms ship with paid plans

5. Confidentiality

Control	Status	Evidence
Confidential data identified and catalogued	In place	GDPR doc Annex B data catalogue
Encryption in transit (TLS 1.3) and at rest (AES-256)	In place	§3.5
Customer telemetry minimised at source (3-level local scrubbing)	In place	Privacy levels; 13-pattern <code>scrubPii()</code>
Secrets shown once, stored hashed	In place	<code>vk_</code> key lifecycle
Tier-based retention with hard deletion	In place	7d / 90d / 1y; GDPR doc §7
Deletion on request, including backup aging ($\leq 30d$)	In place	GDPR doc §7.3
Tenant isolation (customers see only their own data)	In place	Per-user scoping in API and dashboard
Confidentiality clauses with all vendors	In place	Via DPAs, GDPR doc Annex A

6. Known Gaps

A readiness document that lists no gaps is not credible. These are Voight's, stated plainly:

#	Gap	Criteria affected	Path to closure
1	No independent penetration test performed yet	CC4, CC7	Commission before the Type II engagement
2	Segregation of duties is structurally limited — a founding team of this size cannot fully separate development, deployment, and review	CC1, CC8	Formal PR review and role separation as the team grows; compensating control today is full audit logging
3	No formal risk register / annual risk assessment ceremony	CC3	Established as part of audit preparation (compliance platform onboarding)
4	Recovery procedure not yet formally tested (no documented RTO/RPO exercise)	Availability	Scheduled restore test; results recorded in the next revision
5	No public status page or contractual SLA yet	Availability	Ships with v1.0 / paid tiers
6	No formal security-awareness training programme	CC1	Formalises with first hires; founders maintain practice directly today

None of these gaps is hidden from the reader, and none is inconsistent with engaging a Type II audit — they are the normal maturity items a readiness phase exists to close.

7. Inherited Controls

A material share of any SaaS company's SOC 2 posture is inherited from its infrastructure providers. Voight's three vendors each hold a current SOC 2 Type II report:

Vendor	Service	Attestation	Inherited controls
Vercel	Dashboard hosting	SOC 2 Type II, ISO 27001	Physical security, network infrastructure, DDoS mitigation
Railway	API + database	SOC 2 Type II	Physical security, volume encryption, backup infrastructure
Privy	Authentication	SOC 2 Type II	Credential handling, auth infrastructure

Inheritance does not transfer certification — Voight's own controls (everything above the infrastructure line) are what a Voight SOC 2 examination would test. But it means the physical and network layers beneath Voight are independently audited today.

8. Roadmap to a Type II Report

The path from this document to an issued SOC 2 Type II report:

1. **Readiness (this document)** — controls designed, documented, and published. ☐ Done.
2. **Gap closure** — the six items in §6, tracked in revisions of this document.
3. **Compliance platform onboarding** — continuous evidence collection (e.g., Vanta, Drata, or Secureframe).
4. **Type I examination** (optional intermediate) — design-of-controls attestation at a point in time.
5. **Observation window** — 3–12 months of control operation with evidence.
6. **Type II examination and report** — issued by a licensed CPA firm; available to customers under NDA.

Voight has deliberately not committed to a public date for steps 3–6. The trigger is enterprise customer demand: when a material engagement requires a Type II report, the examination will be scheduled and this document updated to record it. Until then, this readiness assessment — and the three audited vendors beneath it — is the honest answer to “do you have SOC 2?”.

9. Governance and References

Field	Value
Framework	AICPA Trust Services Criteria (2017, revised points of focus 2022)
Criteria in scope	Security, Availability, Confidentiality
Criteria out of scope	Processing Integrity, Privacy (the latter covered by Voight's GDPR documentation, which applies a stricter regime)
Security contact	team@voight.xyz
Related documents	GDPR (/trust/gdpr) · OWASP LLM Top 10 (/trust/owasp-llm) · NIST AI RMF (/trust/nist-ai-rmf)
Review cycle	Every six months, on material change, and at each audit milestone

Annex A — Document Version History

Version	Date	Change	Author
1.0	2026-06-10	Initial publication. Scope: Security, Availability, Confidentiality.	Voight — Security Office

Contact

For any question about this document, to request additional evidence, or to discuss audit timelines:

Voight — Security Office

team@voight.xyz

voight.xyz/trust · docs.voight.xyz/trust

This document is published by Voight. It is a self-prepared readiness assessment and is not a SOC 2 report, an attestation, or a certification. SOC 2 reports can only be issued by licensed CPA firms following an examination under AICPA standards.